

AppGrid AppExchange Security Review Submission Package

Document version: 2.0

Prepared date: February 14, 2026

1. Executive Summary

AppGrid is a Salesforce-managed package that hosts a React UI within an LWC container and executes business/data operations through Apex.

Security posture summary: - Apex access is controlled with `with sharing` and broad use of `WITH USER_MODE / AccessLevel.USER_MODE`. - Slack tokens are stored in encrypted Salesforce fields (`EncryptedText`) and managed through OAuth flows. - Iframe bridge traffic is validated by source window and allowlisted origins in the LWC host. - Cloudflare is used for hosting static frontend assets; Salesforce business logic and data access stay in Salesforce.

2. Architecture Summary

Architecture includes Salesforce UI/runtime, Cloudflare-hosted frontend assets, and Slack API integration.

See full diagram: - `appExchange docs/ AppExchange_Architecture_Diagram.md`

3. Control Areas (Concise)

3.1 Platform Access Controls

- Core classes operate with `with sharing`.
- Query/DML operations use user-mode enforcement patterns.
- Message channels and component boundaries are explicitly controlled.

3.2 Cloudflare External Hosting Controls

- LWC points to controlled app URL/origins.
- CSP trusted sites and remote site settings are configured.
- No Salesforce customer records are persisted in Cloudflare.

- Cloudflare is treated as a static asset delivery tier, not a system-of-record backend.

3.3 Slack Integration Controls

- Slack integration uses OAuth-based token model with encrypted token storage.
- Missing/revoked/expired token paths are handled with explicit failure responses.
- Slack integration has enable/disable configuration controls.

4. Data Handling Summary

- Primary data processing occurs within Salesforce (LWC/Apex/SObject model).
- Cloudflare serves frontend assets; it is not used to store Salesforce business records.
- Slack integration transmits operational message payloads for enabled features only.
- Sensitive credentials/tokens are encrypted at rest in Salesforce.

5. Scan and Review Status

Static analysis summary: - No Sev1 findings - No Sev2 findings - Remaining findings are documented and justified (ProtectSensitiveData rule context)

Primary evidence: - AgGrid2025GA/CodeAnalyzerReport.html -
AgGrid2025GA/react/documentation/
CODE_ANALYZER_SECURITY_JUSTIFICATION.md

6. Reviewer Focus Areas (Open Items to Close Before Submission)

1. Least-privilege tightening for Slack-related permissions and token exposure boundaries.
2. Cloudflare-specific documentation completeness (integrity, deployment/change control, privacy statement).
3. Slack scope minimization rationale and field-level payload disclosure.
4. Secure-default language alignment (explicit admin enablement model and disable controls).

7. Questionnaire Mapping

Salesforce security questionnaire draft mapped from this package: - appExchange docs/Salesforce_Security_Questionnaire_Draft.md

8. Submission Attachments

Recommended submission set: - This concise package - Architecture diagram (appExchange docs/AppExchange_Architecture_Diagram.md) - Questionnaire draft (appExchange docs/Salesforce_Security_Questionnaire_Draft.md) - Analyzer report and justifications - Cloudflare addendum (hosting/integrity/change control/privacy) - Slack addendum (auth/scopes/payload/secure defaults)

9. Scope

This package is intentionally concise for reviewer readability. Implementation-level evidence is retained in source repositories and mapped in the questionnaire draft.